

Security Scan Report

PornActressDB-Golang-Migration

Scan Date: 2026-04-04

Generated: 2026-04-04 01:38 (UTC+8)

Tool	Version	Status
bandit	1.9.4	Installed
gosec	N/A	Not Installed
semgrep	N/A	Not Installed
go_vet	N/A	Not Installed (Go Not In Sandbox)
manual_review	claude-sonnet	Used For Go Files

Note: gosec, semgrep, and go vet were unavailable in the sandbox environment. Go files were reviewed manually by AI code review agent. Results may be incomplete for Go files.

Executive Summary

Severity	Count	Description
CRITICAL	0	Immediate action required - exploitable vulnerabilities
HIGH	5	Significant risk - should be fixed promptly
MEDIUM	11	Moderate risk - plan for remediation
LOW	8	Minor issues - fix during regular maintenance
TOTAL	24	

Files scanned: 93 total (77 Python, 16 Go)

Detailed Findings

HIGH (5 issues)

[f8dd2450d4fc] cmd/scanner/main.go:130

Type: Path traversal via ignored errors | **CWE:** CWE-252 | **Tool:** go-manual-review
filepath.Abs() error is ignored with blank import, could lead to using wrong directory

Fix: Check error from filepath.Abs() before using result

[221184a64751] cmd/scanner/main.go:137

Type: Path traversal via ignored errors | **CWE:** CWE-252 | **Tool:** go-manual-review
filepath.Abs() error is ignored with blank import, could lead to using wrong directory

Fix: Check error from filepath.Abs() before using result

[1a51b4ca4efc] cmd/scanner/main.go:173

Type: Path traversal via ignored errors | **CWE:** CWE-252 | **Tool:** go-manual-review
filepath.Abs() error is ignored with blank import, could lead to using wrong directory

Fix: Check error from filepath.Abs() before using result

[6cc82255f826] cmd/scanner/main.go:181

Type: Path traversal via ignored errors | **CWE:** CWE-252 | **Tool:** go-manual-review
filepath.Abs() error is ignored with blank import, could lead to using wrong directory

Fix: Check error from filepath.Abs() before using result

[17034c8dde4f] pkg/database/jsondb.go:687

Type: No path validation in MergeFromFile | **CWE:** CWE-22 | **Tool:** go-manual-review
User-controlled sourceFile path not validated, could read arbitrary files

Fix: Validate sourceFile is within expected directory before reading

MEDIUM (11 issues)

[541788ce3d06] pkg/mover/mover.go:489

Type: TOCTOU race condition | **CWE:** CWE-367 | **Tool:** go-manual-review
os.Stat() followed by use in generateUniqueName creates race condition between check and file creation

Fix: Use os.OpenFile with O_CREATE

[1ed25625d9ab] pkg/cache/cache.go:189

Type: Path from untrusted index used in os.Remove | **CWE:** CWE-426 | **Tool:** go-manual-review
FilePath from cache index not validated before deletion, could delete unintended files

Fix: Validate FilePath is within cache directory before removing

[55072fdc311e] pkg/cache/cache.go:277

Type: Path from untrusted index used in os.Remove | **CWE:** CWE-426 | **Tool:** go-manual-review
FilePath from cache index not validated before deletion, could delete unintended files

Fix: Validate FilePath is within cache directory before removing

[9328cae31ecf] pkg/cache/cache.go:317

Type: Path from untrusted index used in os.Remove | **CWE:** CWE-426 | **Tool:** go-manual-review
FilePath from cache index not validated before deletion, could delete unintended files

Fix: Validate FilePath is within cache directory before removing

[11f3485a628c] pkg/cache/cache.go:391

Type: Path from untrusted index used in os.Remove | **CWE:** CWE-426 | **Tool:** go-manual-review
FilePath from cache index not validated before deletion, could delete unintended files

Fix: Validate FilePath is within cache directory before removing

[315f4ab72d0a] pkg/cache/cache.go:440

Type: Path from untrusted index used in os.Remove | **CWE:** CWE-426 | **Tool:** go-manual-review
FilePath from cache index not validated before deletion, could delete unintended files

Fix: Validate FilePath is within cache directory before removing

[c5c8cd81e7e1] pkg/safefile/safefile.go:35

Type: Root file access model may leak data | **CWE:** CWE-426 | **Tool:** go-manual-review
os.OpenRoot allows relative path traversal if dir contains symlinks

Fix: Use filepath.EvalSymlinks and validate clean path matches original

[8e6c139b4f72] pkg/safefile/safefile.go:50

Type: Root file access model may leak data | **CWE:** CWE-426 | **Tool:** go-manual-review
os.OpenRoot allows relative path traversal if dir contains symlinks

Fix: Use filepath.EvalSymlinks and validate clean path matches original

[8c396114dabf] pkg/safefile/safefile.go:65

Type: Root file access model may leak data | **CWE:** CWE-426 | **Tool:** go-manual-review
os.OpenRoot allows relative path traversal if dir contains symlinks

Fix: Use filepath.EvalSymlinks and validate clean path matches original

[4f1f57e3c633] pkg/safefile/safefile.go:75

Type: Root file access model may leak data | **CWE:** CWE-426 | **Tool:** go-manual-review
os.OpenRoot allows relative path traversal if dir contains symlinks

Fix: Use filepath.EvalSymlinks and validate clean path matches original

[c82fce5f63c3] pkg/safefile/safefile.go:101

Type: Root file access model may leak data | **CWE:** CWE-426 | **Tool:** go-manual-review
os.OpenRoot allows relative path traversal if dir contains symlinks

Fix: Use filepath.EvalSymlinks and validate clean path matches original

LOW (8 issues)

[03cb44b77a33] .github/agent_verify.py:5

Type: B404:blacklist | **CWE:** CWE-78 | **Tool:** bandit
Consider possible security implications associated with the subprocess module.

[cea771426dc1] .github/agent_verify.py:31

Type: B603:subprocess_without_shell_equals_true | **CWE:** CWE-78 | **Tool:** bandit
subprocess call - check for execution of untrusted input.

[b42a36539495] .github/agent_verify.py:121

Type: B603:subprocess_without_shell_equals_true | **CWE:** CWE-78 | **Tool:** bandit
subprocess call - check for execution of untrusted input.

[0da34339c67c] .github/cleanup_project.py:86

Type: B110:try_except_pass | **CWE:** CWE-703 | **Tool:** bandit
Try, Except, Pass detected.

[2844de3eaa72] run.py:15

Type: B110:try_except_pass | **CWE:** CWE-703 | **Tool:** bandit

Try, Except, Pass detected.

[5e6b4d5a9dd6] tests/test_cache_manager_security.py:7

Type: B403:blacklist | **CWE:** CWE-502 | **Tool:** bandit

Consider possible security implications associated with pickle module.

[245354a7961f] tools/integration/go_integration.py:7

Type: B404:blacklist | **CWE:** CWE-78 | **Tool:** bandit

Consider possible security implications associated with the subprocess module.

[ddbb7bca9cba] tools/integration/go_integration.py:22

Type: B603:subprocess_without_shell_equals_true | **CWE:** CWE-78 | **Tool:** bandit

subprocess call - check for execution of untrusted input.

Manual Intervention

No issues have reached the 3-attempt threshold. No manual intervention is currently required.